

Secure Fintech App

Owner: hammad

Reviewer:

Contributors:

Date Generated: Mon Jun 29 2026

Executive Summary

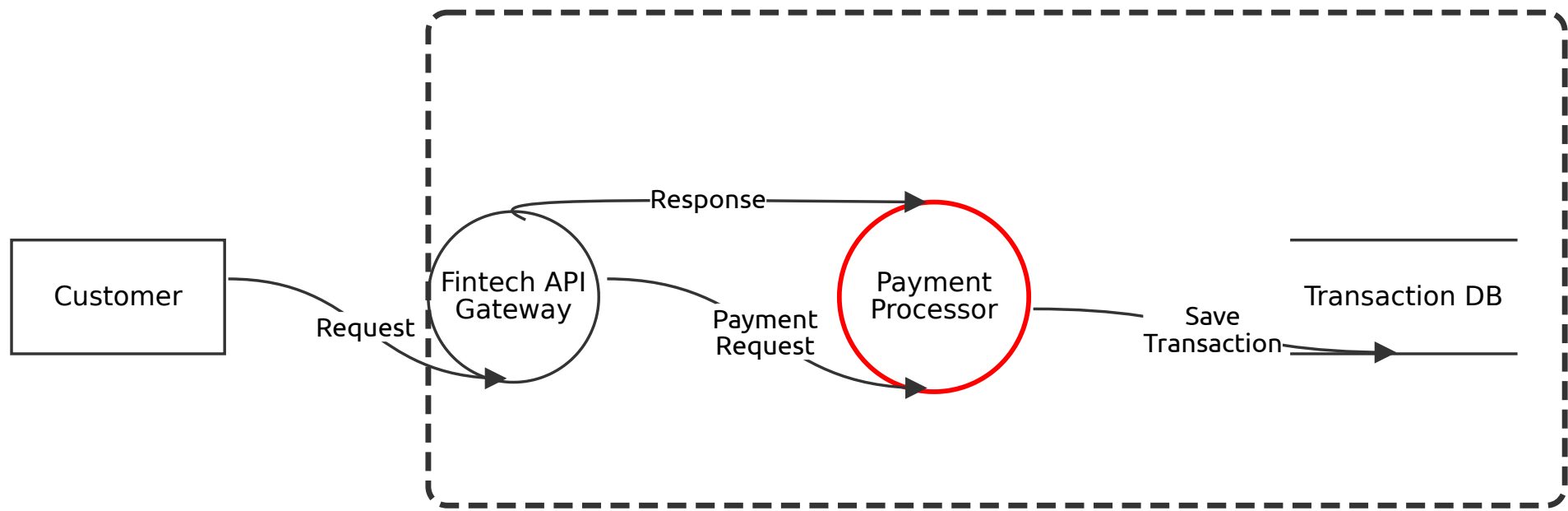
High level system description

Not provided

Summary

Total Threats	4
Total Mitigated	0
Total Open	4
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	4

fintech



fintech

Customer (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Fintech API Gateway (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Payment Processor (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	API Request Spoofing & Credential Stuffing	Spoofing	TBD	Open		An attacker intercepts or crafts malicious requests to the Fintech API Gateway pretending to be a legitimate Customer, leading to unauthorized account access or payment execution.	Implement robust OAuth 2.0 / OIDC authentication, mandatory Multi-Factor Authentication (MFA), and strict API rate limiting/throttling at the Gateway.
3	Payment Parameter Manipulation in Transit	Tampering	TBD	Open		An attacker alters the payment details (e.g., changing the destination account or increasing the amount) in the data stream between the Customer and the Fintech API Gateway.	Enforce TLS 1.3 for all communications crossing the trust boundary. Implement payload signing (e.g., JSON Web Signatures) to verify data integrity before processing.
4	SQL/NoSQL Injection via Payment Fields	Information disclosure	TBD	Open		Malicious Payloads passed through payment fields bypass validation at the Gateway and hit the Payment Processor, allowing unauthorized read access to sensitive financial records in the Transaction DB	Enforce strict input validation (allow-listing) at the API Gateway. Use parameterized queries / Prepared Statements in the Payment Processor, and encrypt sensitive DB columns at rest.
5	Card Testing & Velocity Fraud	Spoofing	TBD	Open		Fraudsters use automated scripts to rapidly test lists of stolen credit card numbers against the Payment Processor via the API to see which accounts are active.	Implement behavioral biometrics, advanced device fingerprinting, and fraud-detection velocity checks (e.g., blocking an IP or account after \$X\$ failed payment attempts within a minute).

Transaction DB (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Payment Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Save Transaction (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------